

ACE-GF：原子密码学实体生成框架

Jian Sheng Wang

jason@yeah.app

加拿大蒙特利尔

2026年2月26日

arXiv:2511.20505v2 [cs.CR] 2026年2月26日

摘要

自主数字实体需要确定性的身份机制，以避免对高价值主密钥进行持久化存储，同时支持凭证轮换及跨异构系统的密码学敏捷性。现有的确定性密钥层级体系与集中式密钥管理系统通常依赖长期存活的根密钥，由此引入结构性单点故障，并使生命周期管理趋于复杂。

本文提出 ACE-GF (Atomic Cryptographic Entity Generative Framework，原子密码学实体生成框架)——一种无需存储种子密钥的身份构建方案。该方案支持确定性、上下文隔离的密钥派生，且无需在静止状态下存储任何主密钥。其构建过程从一个封存工件 (sealed artifact) 和授权凭证出发，在内存中临时重建身份根，采用抗误用的认证加密方案与标准密钥派生原语相结合。派生密钥通过 HKDF 配合显式上下文编码生成，确保跨曲线与应用域的密码学隔离。

该设计天然支持无状态凭证轮换、基于授权的撤销，以及向后量子密码学 (PQC) 域的无中断迁移。此外，框架的参数敏捷性使其能够针对资源受限环境进行优化，确保确定性身份重建在从高性能服务器到低功耗 IoT 节点的各类硬件上均可行，同时不损害底层安全模型。

本工作建立在 MSCIKDF [7] 所引入的概念框架之上。MSCIKDF 提出了多曲线、上下文隔离、PQC 可插拔身份的核心设计目标，但未提供具体构建方案。ACE-GF 的正式协议规范已作为 IETF Internet-Draft [8] 提交。

1 引言

1.1 背景与动机：主种子存储的固有风险

确定性密钥管理方案（如 BIP-32 [6] 和 BIP-39 [4]）通过从单一高熵主种子派生出大量密码学密钥，极大地简化了密钥备份与恢复流程。尽管在实践中获得广泛成功，这些方案从根本上依赖于主种子的长期持久存储。无论是以助记词形式备份——容易遭受物理攻陷、复制和操作失误——还是受硬件安全模块 (HSM) 保护——受制于硬件信任锚和厂商依赖——主种子都代表着一个固有的单点故障 (SPOF)。一旦主种子被攻陷，该层级体系下所有过去和未来派生的密钥将不可挽回地全部暴露。

这种以存储为中心的设计对于自主数字实体 (ADE) 而言尤为不适合，例如 AI 智能体、去中心化服务和大规模 IoT 部署。这类实体通常在没有集中信任锚的情况下运行，需要支持确定性重建、灵活生命周期管理以及跨密码学上下文强隔离的身份机制。对于此类系统，持久存储高价值密钥会带来操作脆弱性，并放大被攻陷的影响。这促使我们寻找将确定性身份与长期密钥存储解耦的替代身份构建方案。

1.2 本文贡献

本文提出 ACE-GF，一种无需存储种子密钥的身份构建方案，旨在解决上述挑战。ACE-GF 并非引入新的密码学原语，而是展示如何将标准密码学构建块进行组合，实现具备以下核心属性的实用身份机制：

- 无种子存储操作。身份根（称为根熵值，Root Entropy Value，REV）仅在执行期间短暂存在于内存中，从不被持久存储或导出。
- 确定性重建。REV 可从封存工件和授权凭证确定性地重建，无需在静止状态下存储任何主密钥，即可可靠地恢复身份。
- 无状态凭证轮换。授权凭证可任意更新，而无需修改或重新派生底层身份根。
- 无状态授权撤销。通过移除凭证组件即可撤销基于授权的访问权限，无需维护服务端状态或密钥层级。
- 严格上下文隔离与密码学敏捷性。密码学密钥通过显式上下文编码派生，确保跨算法和应用域的隔离，防止跨上下文泄露，并支持向后量子密码学（PQC）域的无中断迁移。

此外，本工作还作出以下贡献：（i）引入无种子存储身份构建方案（SSF-ID）的抽象模型，以对系统行为和安全目标进行推理；（ii）提出基于成熟密码学原语的具体实例化方案，并附以基于博弈的安全论证。

1.3 论文结构

本文其余部分组织如下：第 2 节回顾确定性密钥派生与密钥管理系统的相关工作；第 3 节介绍密码学预备知识与用于推理无种子存储身份构建方案的抽象定义；第 4 节阐述 ACE-GF 构建方案；第 5 节进行安全性分析；第 6 节讨论实现注意事项与部署场景；第 7 节对全文进行总结。

图 1：从以密钥为中心到以身份为中心的安全架构演进。左侧：传统系统依赖持久化的私钥或种子材料的静态存储。右侧：ACE-GF 以身份基底替代持久密钥，按需在上下文中临时派生密码学材料。

2 相关工作与比较分析

本节回顾现有的确定性密钥管理与身份系统方法，并将 ACE-GF 置于更广泛的设计空间中加以定位。本节的目标并非声称优于已有系统，而是阐明不同方案在持久性、信任假设、生命周期管理和密码学隔离等方面所做的不同设计权衡。

2.1 层级确定性密钥管理

层级确定性（HD）钱包构建方案（最具代表性的是 BIP-32 [6] 和 BIP-39 [4]）是加密货币及相关系统中确定性密钥管理的主流范式。这些方案从单一主种子派生出大量密码学密钥家族，提供简洁且用户友好的备份和恢复模型。

然而，HD 钱包从根本上围绕主种子的长期持久化而设计。无论种子以直接存储、助记词编码还是口令保护的形式存在，它都是所有派生密钥的根，因此构成单点故障。一旦被攻陷，所有派生路径和密码学域中的密钥将永久暴露。

从系统视角来看，HD 构建方案对于细粒度域隔离和生命周期管理的支持也十分有限。所有派生密钥最终根植于相同的熵源和派生函数，BIP-39 中的口令机制主要用于生成替代的主密钥，而非支持无状态凭证轮换或授权撤销。因此，HD 钱包非

常适合具有静态备份需求的个人用户，但与长期存活、自主或多上下文数字实体的需求匹配度较低。

2.2 集中式密钥管理服务

集中式密钥管理服务（KMS）（如主要云平台提供的服务）代表了设计空间中的另一个方向。这些系统避免向应用程序暴露原始密钥材料，并支持托管式密钥轮换、访问控制和审计，通常由经过认证的硬件安全模块提供支撑。

虽然在企业环境中行之有效，但集中式 KMS 解决方案依赖可信基础设施、持久化的服务端状态以及与服务运营商之间的显式信任关系。身份材料不能仅由客户端独立确定性重建，可用性、撤销和策略执行均由集中控制平面进行中介。这些特性限制了其在去中心化系统和必须独立于持续基础设施信任运行的自主数字实体中的适用性。

2.3 硬件安全模块与安全元件

硬件安全模块（HSM）、可信平台模块（TPM）和安全元件为长期密钥存储提供强物理保护，广泛应用于高保障环境。从设计上看，这些设备在内部保留主密钥并通过受控接口限制其使用。

尽管具有安全优势，基于硬件的解决方案在可移植性、部署灵活性和生命周期管理方面引入了约束。身份连续性与特定设备或厂商绑定，恢复或迁移通常需要专门流程。虽然 HSM 可缓解某些攻击向量，但并不能消除对持久主密钥的依赖，因此与完全消除种子存储的方案是正交关系。ACE-GF 被设计为软件层面的构建方案，可独立于专用硬件运行，同时需要在需要额外保护时与可信执行环境（TEE）兼容。

2.4 早期概念工作：MSCIKDF

ACE-GF 的概念基础最早在 MSCIKDF [7] 中探索，该文提出了单根、多曲线、上下文隔离、PQC 可插拔的密码学身份原语及无状态密钥轮换的核心设计目标。MSCIKDF 阐明了上下文隔离、多曲线独立性、零可链接性和无状态轮换等关键架构属性，但停留于抽象需求层面，未提供具体的密码学构建方案、正式安全模型或实例化。

ACE-GF 在此基础上推进：（i）提供仅基于标准原语（AES-GCM-SIV、HKDF-SHA256、Argon2id）的具体构建方案；（ii）通过封存/解封（Seal/Unseal）机制实现身份与授权的清晰分离；（iii）建立推理无种子存储身份的抽象模型（SSF-ID）；（iv）在标准密码学假设下提供安全论证。（注：MSCIKDF 为本文第一版，arXiv:2511.20505。）

2.5 比较分析

为阐明现有方案间的设计差异，表 1 总结了代表性身份与密钥管理模型的关键属性。比较重点在于信任假设、持久性需求、生命周期能力和密码学隔离，而非绝对安全保证。

表 1：身份与密钥管理方案比较

属性	ACE-GF	BIP-32/39	集中式 KMS	HSM / TPM
静止状态存储持久化主密钥	否	是	是	是
确定性身份重建	是	是	否	否
无状态凭证轮换	是	否	否	否
无状态授权撤销	是	否	否	否

显式密码学上下文隔离	是	有限	是	有限
后量子迁移支持†	是	否	有限	有限
依赖集中信任	否	否	是	是

†无需重新注册或重新生成现有身份密钥。部分 KMS 厂商和 HSM 固件支持单独的 PQC 密钥类型，但缺乏跨经典域和后量子域保持身份连续性的统一迁移路径。

如表所示，ACE-GF 在设计空间中占据独特位置。它在保留确定性身份重建能力的同时，消除了持久化主密钥存储，并支持无状态生命周期操作。这些属性与去中心化和自主部署模型高度契合——在这些场景中，长期可用性、独立于基础设施信任以及受控撤销是首要关注点。

3 预备知识与抽象模型

本节介绍贯穿全文使用的密码学原语与抽象定义。这些定义的目的并非引入新的密码学原语，而是为推理无种子存储身份构建方案的行为、安全目标和生命周期属性提供紧凑而精确的框架。

3.1 密码学构建块

ACE-GF 完全由成熟的密码学原语构建而成。以下简要回顾这些原语的相关属性及其在整体系统设计中的作用。

抗误用认证加密（AES-GCM-SIV）。

AES-GCM-SIV [2] 是一种提供随机数抗误用性的认证加密方案。与标准 AES-GCM 在随机数复用时会灾难性失败不同，AES-GCM-SIV 即使在随机数复用时也能保持机密性，前提是加密密钥保持秘密。此属性使得对高熵身份材料的确定性封存无需维护加密状态或随机性，对于无种子存储身份重建至关重要。

显式上下文编码的密钥派生（HKDF-SHA256）。

HKDF-SHA256 是一种基于 HMAC 的密钥派生函数，遵循先提取后扩展的范式 [3]。在 ACE-GF 中，HKDF 通过 info 参数使用显式结构化上下文字符串。该设计在曲线、协议和应用域之间强制执行密码学隔离，确保一个上下文中的密钥泄露不影响在其他上下文中派生的密钥。

内存硬化凭证派生（Argon2id）。

Argon2id [1] 是一种内存硬化的基于口令的密钥派生函数，旨在抵抗离线暴力破解和时间-空间权衡攻击。ACE-GF 专门使用 Argon2id 从人工选择的授权凭证派生封存密钥，从而提高对封存身份工件进行离线猜测攻击的计算成本。

3.2 无种子存储身份的抽象模型

为推理 ACE-GF 的行为和安全属性，本文引入无种子存储身份构建方案的抽象模型。该模型作为描述性框架，不主张任何密码学创新。

一个无种子存储身份方案（记为 S ）由以下多项式时间算法组成：

- $\text{Setup}(1^\lambda) \rightarrow \text{params}$ ：初始化安全参数 λ 的公共系统参数。
- $\text{Seal}(\text{params}, \text{Cred}) \rightarrow \text{SA}$ ：接受授权凭证 Cred ，生成以受保护形式编码身份根的封存工件 SA 。

- $\text{Unseal}(\text{params}, \text{SA}, \text{Cred}) \rightarrow \text{REV} \cup \{ \perp \}$: 给定封存工件和候选凭证，在认证成功时重建根熵值 REV ，否则输出 $\perp$ 。身份根仅在此操作期间临时存在。
- $\text{Derive}(\text{REV}, \text{Ctx}) \rightarrow \text{Key}$: 从根熵值和编码了算法、域及应用语义的显式上下文描述符 Ctx 派生密码学密钥。
- $\text{RotateCredential}(\text{SA}, \text{Cred}_{\text{old}}, \text{Cred}_{\text{new}}) \rightarrow \text{SA} \cup \{ \perp \}$: 将封存工件更新为将相同底层身份根绑定到新授权凭证，而不修改身份本身。

正确性。对于任何有效凭证 Cred 及在 Cred 下生成的封存工件 SA ，以下等式成立：

$$\text{Unseal}(\text{params}, \text{SA}, \text{Cred}) = \text{REV}$$

反之，对于任何错误凭证，解封操作以压倒性概率失败。

该抽象模型捕捉了无种子存储身份系统底层身份与授权之间的本质分离。具体实例化（如 ACE-GF）规定了封存工件的构建方式、凭证的绑定方式，以及如何使用标准密码学原语实现上下文隔离派生。

4 ACE-GF 构建方案

本节将 ACE-GF 的具体构建方案作为第 3 节所引入抽象无种子存储身份模型的实例化加以呈现。该设计遵循一个核心原则：身份与授权清晰分离。身份根决定所有密码学身份材料，而授权凭证控制对该根的访问，但不成为身份本身的一部分。

4.1 整体架构

ACE-GF 的核心是一个高熵身份根，称为根熵值（REV）。REV 唯一定义实体的密码学身份，并作为所有派生密钥的唯一熵源。授权凭证不影响密钥派生；相反，它们仅用于保护对 REV 的访问。

该构建方案因此由两条逻辑独立的流水线组成：(i) 身份流水线，通过上下文隔离派生从 REV 确定性地派生密码学密钥；(ii) 授权流水线，通过绑定到凭证的封存工件控制对 REV 的访问。这种分离使得确定性身份连续性与无状态凭证更新和撤销得以并存。

图 2：ACE-GF 系统架构。箭头表示数据流语义。该设计将确定性身份生成（左侧）与安全封存生命周期（右侧）分离。架构强制要求：身份仅依赖于 REV，而授权仅依赖于口令绑定。

4.2 身份根生成与封存

身份根生成。在初始化时，系统采样一个均匀随机的 256 位值

$$\text{REV} \leftarrow \{0, 1\}^{256}$$

作为身份根。REV 从不被持久存储或导出，仅在执行期间临时存在于内存中。

封存密钥派生。授权凭证

Cred （例如用户或管理员提供的口令）通过内存硬化密钥派生函数转换为高熵对称封存密钥：

$$K_{\text{seal}} \leftarrow \text{Argon2id}(\text{Cred})$$

此步骤提高了对封存工件实施离线猜测攻击的计算成本。

确定性封存。身份根 REV 在 K_{seal} 下使用 AES-GCM-SIV 加密，生成封存工件 SA：

$$\text{SA} \leftarrow \text{Enc}_{K_{\text{seal}}}(\text{N}_{\text{fixed}}, \text{REV})$$

所有封存操作使用固定的公共随机数 N_{fixed} 。AES-GCM-SIV 的随机数抗误用性确保即使随机数被复用，只要封存密钥保持秘密，密文的机密性仍得以保持。此设计选择使得无需维护加密状态或随机性即可确定性重建封存工件。

存储模型。仅封存工件 SA 被持久存储（例如以助记词编码或不透明密文数据块的形式）。REV 在封存后立即从内存中安全擦除。任何时候都不存在未加密的身份根材料静态存储。

4.3 上下文隔离的密钥派生

ACE-GF 中的所有密码学密钥均通过带显式上下文编码的 HKDF 从 REV 确定性派生。该机制在算法、协议和应用域之间强制执行密码学隔离。

上下文结构。每次派生由结构化上下文元组参数化：

$\text{Ctx} = (\text{AlgID}, \text{Domain}, \text{Index})$

其中：

- AlgID 标识目标密码学算法或曲线（如 Ed25519、Secp256k1、Dilithium）；
- Domain 指定应用域（如签名、加密、认证）；
- Index 提供应用特定的派生索引。

派生流程。密钥派生流程如下：

$\text{PRK} \leftarrow \text{HKDF-Extract}(\text{salt}, \text{REV})$

$\text{Key} \leftarrow \text{HKDF-Expand}(\text{PRK}, \text{Ctx}, L)$

上下文元组作为 info 参数传递给 HKDF-Expand，确保在不同上下文下派生的密钥在计算上相互独立。

隔离保证。在 HKDF 的伪随机性假设下，以不同上下文元组派生的任意两个密钥与随机值不可区分且相互独立。因此，一个算法或应用域中密钥的泄露不能恢复其他域的密钥，也不会透露底层 REV 的任何信息。

后量子密码学就绪性。对后量子密码学的支持自然源于基于上下文的派生模型。引入后量子算法（如 Dilithium）时，只需使用新的 AlgID 值，即可产生独立的派生域，而无需修改身份根、封存工件或任何已派生的经典密钥，从而实现无中断迁移。

4.4 身份生命周期管理

身份与授权的分离使得无需重新生成密钥或维护持久状态即可进行生命周期操作。

无状态凭证轮换。更新授权凭证时，系统首先通过以下操作重建身份根：

$\text{REV} \leftarrow \text{Unseal}(SA, \text{Cred}_{\text{old}})$

然后在新凭证下重新封存相同的 REV：

$SA' \leftarrow \text{Seal}(\text{REV}, \text{Cred}_{\text{new}})$

所有派生密钥保持不变，因为它们仅依赖于 REV。不需要服务端状态或密钥重新生成。

基于授权的撤销。通过使相关凭证组件不可用（如删除管理员控制的密钥）来实现授权撤销。由于重建 REV 需要完整的凭证材料，撤销是即时且永久的，无需修改身份派生密钥或维护撤销状态。

这些机制共同实现了具有灵活无状态生命周期控制的确定性身份连续性，非常适合去中心化和自主数字系统。

算法 1 和算法 2 以正式伪代码形式汇总了 ACE-GF 构建方案。

算法 1：ACE-GF 核心操作

```
1: 过程 Setup( $1^\lambda$ )
2: 选择安全级别  $\lambda$  对应的 Argon2id 参数 ( $m, t, p$ )
3: 固定公共随机数  $N_{\text{fixed}}$ 
4: 返回  $\text{params} \leftarrow (\lambda, m, t, p, N_{\text{fixed}})$ 
5: 结束过程

6: 过程 Seal( $\text{params}, \text{Cred}$ )
7:  $\text{REV} \leftarrow \{0, 1\}^{256}$  采样身份根
8:  $K_{\text{seal}} \leftarrow \text{Argon2id}(\text{Cred}; m, t, p)$ 
9:  $\text{SA} \leftarrow \text{AES-GCM-SIV.Enc}(K_{\text{seal}}, N_{\text{fixed}}, \text{REV})$ 
10: 清零  $K_{\text{seal}}, \text{REV}$ 
11: 返回 SA
12: 结束过程

13: 过程 Unseal( $\text{params}, \text{SA}, \text{Cred}$ )
14:  $K_{\text{seal}} \leftarrow \text{Argon2id}(\text{Cred}; m, t, p)$ 
15:  $\text{REV} \leftarrow \text{AES-GCM-SIV.Dec}(K_{\text{seal}}, N_{\text{fixed}}, \text{SA})$ 
16: 清零  $K_{\text{seal}}$ 
17: 如果解密失败，返回  $\perp$ 
18: 返回 REV 临时值；调用方须清零
19: 结束过程
```

4.5 受限环境中的参数敏捷性

对于内存硬化函数，一个常见批评是其对资源受限 IoT 硬件的计算需求较高。ACE-GF 通过参数敏捷性解决这一问题。Argon2id 参数 (m, t, p) 可根据设备的可用 SRAM 和功耗特性进行调整。

在存在硬件信任锚（如 ARM TrustZone 或安全飞地）的场景中，由于封存工件 SA 受到硬件强制访问策略的保护，内存硬化需求可安全降低。这种分层方式使 ACE-GF 能够从高熵口令保护（需要较高的 mcost）扩展到硬件耦合身份（仅需最小计算开销），同时维持统一的身份派生逻辑。

5 安全分析与论证

本节在标准密码学假设下为 ACE-GF 提供安全论证。分析旨在为构建方案所声明的安全属性提供依据，而非引入新的安全概念或原语。我们重点分析封存工件的机密性以及在不同密码学上下文中派生密钥的隔离性。

5.1 安全模型与假设

我们的安全论证依赖以下广泛接受的假设：

- HKDF-SHA256。HKDF-SHA256 在以密码学哈希函数实例化时被建模为安全的伪随机函数（PRF），并在随机预言机模型中分析。
- AES-GCM-SIV。AES-GCM-SIV 被假设为安全的抗误用认证加密（MRAE）方案，即使在随机数复用时也能保持机密性和完整性。

我们进一步假设提供给系统的授权凭证对其预期威胁模型具有足够的熵，且使用的标准密码学实现不引入第 5.4 节讨论以外的旁路漏洞。

5.2 封存工件的机密性

封存工件 SA 以加密形式编码身份根 REV，是系统存储的唯一持久对象。我们在选择明文攻击（IND-CPA）模型下分析其机密性。

命题 1（封存工件的机密性）。ACE-GF 生成的封存工件对任何在没有正确授权凭证的情况下运行的概率多项式时间敌手，在计算上与随机值不可区分。

论证思路。身份根 REV 通过 AES-GCM-SIV 在由 Argon2id 从授权凭证派生的封存密钥 K_{seal} 下加密。所有封存操作使用固定公共随机数。由于 AES-GCM-SIV 的随机数抗误用性，即使随机数被复用，只要封存密钥保持秘密，密文的机密性仍得以保持。

因此，从 SA 恢复 REV 需要攻破 AES-GCM-SIV 的 IND-CPA 安全性，或猜中正确的封存密钥。由于 K_{seal} 由内存硬化函数从凭证派生，离线猜测攻击的计算成本高昂且受凭证熵的限制。在上述假设下，封存工件不会泄露关于身份根的信息。

5.3 派生密钥的上下文隔离

ACE-GF 中的所有密码学密钥均通过带显式上下文编码的 HKDF 从身份根派生。我们分析此派生机制提供的隔离保证。

命题 2（上下文隔离）。在不同上下文描述符下派生的任意两个密钥在计算上是独立的，即使敌手获得其中一个派生密钥的完整知识。

论证思路。派生密钥使用 HKDF-Expand 计算，上下文描述符作为 info 参数传入。在 HKDF 的 PRF 假设下，不同 info 值对应的输出是伪随机且独立的。因此，与某一算法、域或应用上下文关联的派生密钥的知识，不能计算出不同上下文下派生的密钥，也不会透露底层身份根的信息。

此属性确保了跨密码学曲线、协议和应用域的隔离，并直接支持经典算法和后量子算法的并行使用，而不会产生交叉污染。

5.4 安全边界与局限性

ACE-GF 提供的安全保证受以下固有局限性约束：

凭证熵。封存工件的机密性最终取决于授权凭证的熵。虽然 Argon2id 显著提高了离线猜测攻击的成本，但如果使用低熵凭证面对足够强大的敌手，构建方案无法防止被攻陷。

旁路暴露。安全模型不考虑对临时存在于内存中的身份根的高级旁路攻击，如冷启动攻击或细粒度时序分析。具有较高威胁模型的部署场景应在可信执行环境（TEE）中执行解封和密钥派生操作，如第

6.5 节所述。

这些局限性反映了基于软件身份系统中的基本权衡，与 ACE-GF 的密码学结构本身是正交的。

6 应用、实现与部署

本节讨论 ACE-GF 的实际实现注意事项、部署环境以及迁移能力。重点在于可演示性、可移植性和互操作性，而非针对特定平台的性能优化。

6.1 参考实现与确定性

我们提供用 Rust 编写的 ACE-GF 确定性参考实现。该实现作为概念验证，用于验证第 3 节和第 4 节所述的构建方案。所有安全声明均源于正式规范和底层密码学假设；参考实现本身不构成安全模型的一部分。

核心库以兼容 no_std 的 Rust 实现，提供以下功能：

- 采样 256 位根熵值 (REV) ；
- AES-GCM-SIV 对身份根的封存与解封；
- 带显式固定上下文编码的 HKDF-SHA256 扩展；
- Ed25519、Secp256k1 和 X25519 的确定性密钥派生；
- 凭证绑定和基于授权的撤销机制。

所有敏感值（包括 REV、中间种子、封存密钥和派生私钥）仅临时存在于内存中，在离开作用域时被显式清零。使用栈本地缓冲区和 zeroize trait 以最小化内存残留。

6.2 可移植性与跨平台一致性

参考实现设计为跨广泛环境的可移植性，已成功编译至以下平台：

- 通过 C 兼容 FFI 绑定的本地平台；
- WebAssembly 目标；
- iOS 和 Android 移动环境。

对于固定的封存工件和授权凭证，所有受支持平台产生逐字节相同的输出。此确定性在不同架构和端序下均成立，因为随机数格式、上下文标签和编码约定均完整指定且固定。任何平台都不会持久存储身份根或任何派生的密钥材料。

6.3 验证工件与概念验证

公共参考代码库提供辅助工件，用于支持对方案行为的验证、实验和独立重现。这些工件仅为演示性质，非生产就绪软件。

命令行界面。最小化命令行界面演示核心操作，包括身份生成、确定性重建、无状态凭证轮换，以及跨密码学域的派生身份地址检查。

测试套件。全面的单元测试验证密码学核心和系统不变量的正确性，包括：

- 跨上下文隔离派生的密码学独立性；
- 用于双控和撤销场景的组合授权凭证的正确处理；

- Diffie-Hellman 密钥协商和端到端加密密钥解析；
- 将既有私钥轮转迁移到确定性锚定身份根的往返测试。

确定性测试向量。一组以 JSON 格式编码的标准化测试向量验证跨平台的严格确定性行为。这些向量包含使用单因子授权凭证的配置，以及包含复杂 UTF-8 字符（如非拉丁文字和表情符号）的输入，以验证健壮且一致的凭证处理。

参考实现及相关工件可在以下地址获取：

<https://github.com/ya-xyz/acegf-playground>

6.4 性能原理与优化

ACE-GF 的计算成本主要集中于初始 Unseal 操作。一旦 REV 临时重建完成，后续通过 HKDF-SHA256 进行的密钥派生在计算上可忽略不计 [3, 5]。

为优化 IoT 部署，我们提出基于会话的具现化策略：在设备启动序列或用户会话初始化期间重建一次 REV，并将其保存在可清零的易失性内存中。这将 Argon2id 开销限制为单次“冷启动”事件。对于亚瓦特级设备，ACE-GF 支持异步封存模型：凭证密集型密钥派生委托给可信配对设备（如移动网关），使终端节点仅需执行轻量级 AES-GCM-SIV 解密即可实现身份连续性。

6.5 部署与迁移注意事项

ACE-GF 被设计为软件层面的身份构建方案，不依赖集中式基础设施或专用硬件。该方案可在完全去中心化的环境中部署，同时保留确定性身份重建和严格密码学隔离。当需要更高保障时，解封和密钥派生操作可在可信执行环境（如 Intel SGX 或 ARM TrustZone）中执行，以缓解第 5.4 节讨论的旁路风险。

显式上下文隔离使互操作性和长期可部署性得以实现。引入包括后量子原语在内的新密码学算法时，仅需分配新的上下文标识符。这允许经典密钥和后量子密钥在单一稳定身份根下共存，无需重新注册、重新生成现有域的密钥或修改已存储的封存工件。

除前瞻性密码学敏捷性外，ACE-GF 还支持从现有系统实际迁移。通过使用保留上下文标签从身份根派生专用封装密钥对旧有私钥进行加密，可将其纳入管理。此方法实现了对历史密钥和新派生密钥的统一管理，同时保留遗留系统的原始身份语义。

遗留密钥嵌入（可选）。尽管 ACE-GF 被定义为无种子存储身份构建方案，实际部署中常包含长期遗留私钥（如控制现有区块链资产的 ECDSA 密钥）。为便于采用，我们提供一个可选辅助机制，将此类密钥嵌入 ACE-GF 身份，而不修改构建方案或影响安全模型。

给定遗留私钥 sk_{legacy} 和授权凭证 Cred，辅助函数

$$\text{wei_to_crypto_entity} : (sk_{\text{legacy}}, \text{Cred}) \rightarrow \text{SA}$$

生成一个封存工件，其派生身份重现相同的遗留地址，同时支持 ACE-GF 的全套上下文隔离密钥。

该辅助函数仅作为实际迁移层，不引入新假设、不改变 ACE-GF 构建方案，也不影响正式安全分析的任何方面。

7 结论与未来工作

本文提出了 ACE-GF，一种无种子存储身份构建方案，旨在解决确定性密钥管理系统中长期主密钥存储的固有风险。通过将抗误用认证加密与上下文隔离密钥派生相结合，ACE-GF 实现了确定性身份重建，而无需在静止状态下持久存储任何主密钥。该设计支持无状态凭证轮换、基于授权的撤销，以及跨密码学算法和应用域的强互操作性。

ACE-GF 展示了如何独立于授权凭证维护稳定的密码学身份，使身份连续性在凭证随时间演变时得以保持。通过显式上下文编码，构建方案在签名、加密、认证和资产控制域之间强制执行隔离，并自然支持经典密码学算法和量子密码学算法的共存。这些属性使 ACE-GF 非常适合需要可移植、可重建和长期存活身份的去中心化和自主数字系统。

该构建方案完全依赖成熟的密码学原语，并在标准假设下继承其安全属性。通过确保身份根仅临时存在于内存中且从不被存储或导出，ACE-GF 降低了密钥被攻陷的系统性影响，并在各平台和信任边界间实现一致的身份行为。

ACE-GF 的正式协议规范已作为 IETF Internet-Draft [8] 提交，为实现者提供了用于互操作部署的精确数据结构、编码约定和测试向量。

未来工作。未来工作将聚焦于两个互补方向。首先，计划在标准模型中开发正式安全证明，减少对随机预言机假设的依赖，为在可组合系统中的部署提供更强的安全保证。其次，打算在实际部署条件下评估该构建方案，包括在真实可信执行环境（TEE）硬件上对解封和派生操作进行实证旁路分析，并设计相应的缓解策略。

其他方向包括：将标准化的后量子签名和密钥封装机制系统性地集成到上下文隔离派生框架中，以及探索机器间身份、自主智能体协调和长期数字服务等协议层面应用。

未来工作还将涉及在特定 ARM Cortex-M 架构上对 ACE-GF 进行基准测试，并完善自适应参数选择算法，以在去中心化自主传感器网络中自动平衡暴力破解抵抗能力与功耗。

参考文献

[1] A. Biryukov, D. Dinu, D. Khovratovich. Argon2: 用于口令哈希及其他应用的新一代内存硬化函数. IEEE EuroS&P, 2016. doi:10.1109/EuroSP.2016.14.

[2] S. Gueron, A. Langley, Y. Lindell. RFC 8452: AES-GCM-SIV: 随机数抗误用认证加密, 2019.

[3] H. Krawczyk, P. Eronen. RFC 5869: 基于 HMAC 的先提取后扩展密钥派生函数（HKDF）, 2010.

[4] M. Palatinus, P. Rusnak, A. Voisine, S. Bowe. BIP-39: 用于生成确定性密钥的助记词代码, 2013.

[5] P. Rogaway, T. Shrimpton. 确定性认证加密：密钥封装问题的可证明安全处理. 密码学进展 – EUROCRYPT 2006, 第 373–390 页. Springer, 2006.

[6] P. Wuille. BIP-32: 层级确定性钱包, 2012.

[7] J. S. Wang. MSCIKDF: 具有无状态密钥轮换的单根、多曲线、上下文隔离、PQC 可插拔密码学身份原语. 本文 (arXiv:2511.20505) 第一版, 2025年11月.

[8] J. S. Wang. ACE-GF: 原子密码学实体生成框架. IETF Internet-Draft, draft-wang-acegf-protocol-00, 2025年12月.

附录 A 非规范性应用场景

本附录描述 ACE-GF 构建方案所支持的说明性应用场景。本节内容为非规范性，不属于正式系统模型、构建方案或安全分析的一部分。其目的在于为潜在用例提供直觉和背景，而非定义所需功能。

A.1 多曲线身份与资产控制

单一根熵值（REV）确定性地锚定跨异构生态系统的密码学材料，包括签名、密钥协商和加密域（如 Ed25519、Secp256k1、X25519）。通过显式上下文编码，每个派生密钥与所有其他密钥隔离，同时可从相同身份根重建。

此属性支持跨多个密码学环境和平台的统一身份表示，在无需维护多个独立主密钥的情况下，提供一致的资产控制和认证语义。

A.2 授权控制的生命周期

ACE-GF 支持无需依赖持久密钥存储的授权控制身份生命周期。对身份根的访问由在逻辑上与身份本身分离的授权凭证控制，允许凭证随时间独立演变。

凭证更新和撤销可通过修改或移除指定的授权组件来实现，无需更改底层身份根或重新派生现有密码学域。此模型支持组织密钥管理工作流——在这些工作流中，身份连续性必须在授权策略变更时得以保持。